

计算机实体面临威胁：各类计算机、网络通信设备、存放数据的媒体、传输电路、防雷系统、抗电磁干扰系统
 计算机网络系统面临威胁：主机受攻击；敏感数据被泄露/修改；从内网向公网传递的信息被窃听/修改。
 网络面临的典型网络安全威胁：窃听、重传、伪造、篡改、非授权访问、拒绝服务攻击、行为否认、旁路控制、电磁/射频截获、APT攻击、人员疏忽

计算机网络不安全因素

- 偶然性因素
 - 自然灾害
- 人为因素
 - 破坏攻击：监视信息
 - 主动攻击：突破防护、引入恶意代码
 - 被动攻击：物理上
 - 内部人员攻击/分发攻击

计算机网络安全

- 内涵：利用网络安全管理控制和技术措施，保证数据机密性、可用性、完整性
- 外延：凡涉及安全目标的相关技术和理论

安全目标

- 保密性
- 完整性
- 可用性
- 不可否认性：保证信息行为人不能否认其信息行为，提供向第三方证明实体确实参与通信
- 可控性

先进的技术：物理安全、入侵检测、访问控制、审计
 严格的管理：审计跟踪体系
 威严的法律：安全标准、可信、可靠

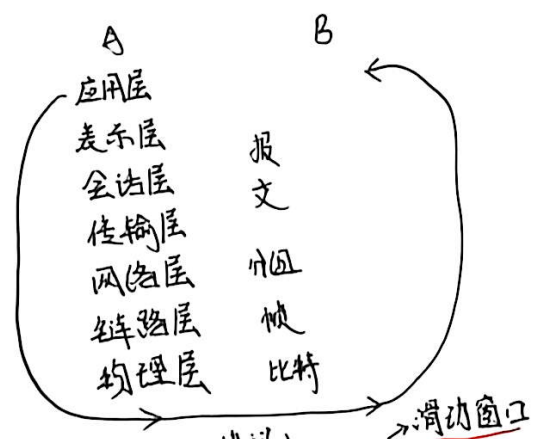
三度要求：温度、湿度、洁净度
 电磁兼容性：电子设备/系统在一定电磁环境下互相兼容，工作时辐射电磁波
 电磁干扰：可通过电磁辐射/传导影响

三种数据交换技术

- 线路交换：两站之间专用通信线路 动态分配资源
- 报文交换：目的地址附在报文上 经多法点 暂存、转发
- 报文分组交换：报文分若干段 走不同路径

拓扑结构

- 星型：中心（集线器、交换机）
 - 优：拓展易、诊断方便
 - 缺：依赖中心、成本高
- 总线型：
 - 优：结构简单
 - 缺：诊断、排查困难
- 环形：
 - 优：控制易
 - 缺：一死全死
- 树形：
 - 优：易拓展
 - 缺：依赖根
- 全互连型（完全图）：
 - 优：可靠
 - 缺：成本高
- 混合型



IP数据报：首部 + 数据区
 TCP/IP传输层通过协议端口来标识通信的应用进程
 端口：地址 信息交互

TCP的流量控制机制：传输层采用可变窗口大小、动态缓冲防止快速发送数据 缓冲区
 TCP的差错控制机制：

- 检验和：差错检测
- 确认：确认已完整受到
- 超时：超时前未确认则视为丢失

密码学 { 密码编码学: 使消息保密 设计
 ↓ 密码分析学: 研究如何破译
 研究信息安全保密

单钥

明文 $\rightarrow E_k \rightarrow$ 密文 $\rightarrow D_k \rightarrow$ 解密后明文

用A的私、B的公加密,再用B的私、A的公解密并验证

双钥

明文 $\xrightarrow{\text{保密}} D_{kA} \rightarrow E_{kB} \rightarrow D_{kB} \rightarrow E_{kA} \rightarrow$ 密文

移位、置换 $\Rightarrow$ 计算

DES原理: 64位明文 $\Rightarrow$ 初始置换 $\Rightarrow$ 乘积变换 $\Rightarrow$ 逆初始置换 $\Rightarrow$ 密文

RSA原理: 确定两素数 p, q $n = pq$ $\phi(n) = (p-1)(q-1)$, 取 e 与 $\phi(n)$ 互质, 取 d 使 $de \bmod \phi(n) = 1$
 n, e 公开

加密: 密文 $= m^e \bmod n = C$

解密: 明文 $= C^d \bmod n = m$

链路加密: 传输密文 结点解、加、传

节点加密: 在一个安全模块中解、加 (不允许节点处有明文)

端到端加密: 始 $\rightarrow$ 终 都为密文传输

数字签名: 消息完整性、身份认证

身份认证 { 通行字
 持证

{ 真: 解/加密
 公证: 发给第三方

PKI: 用公钥密码学原理和技术提供安全服务的通用性基础平台
 透明提供密钥、证书管理

认证机构 CA: 数字证书的签发机构 核心 权威、可信、公正

证书库: 证书的集中存放地

防火墙: 位于被保护网络和外部网络之间执行访问控制策略的一个/一组系统 包括硬/软

允许/阻止业务往来

基本功能 { 过滤进出数据
 管理访问行为
 封锁禁止业务
 记录通过的信息、活动
 检测、告警网络攻击

包过滤防火墙: 网络层 访问控制列表 TCP/IP数据包
 效率高 透明 难于配置 监控、管理

体系结构: ① 双宿宿主主机 冗余路由器 内、外与其通信
 ② 屏蔽主机 单台过滤路由器 堡垒主机为桥梁
 ③ 屏蔽子网 外 $\rightarrow$ 外路由 $\rightarrow$ 内网 - 堡垒主机

包过滤技术限制依据: 源/目的地址、协议类型、源/目的端口、消息类型

包过滤路由器: 默认拒绝

包过滤规则 $\rightarrow$ 分析报头 $\rightarrow$ 应用规则 (不满足任一则丢弃)

代理防火墙: 应用层网关、电路层网关 应用层

额外安全层 内网
 防止内部暴露

请求 $\rightarrow$ 代理服务器处理 (查库、转送) $\rightarrow$ 真实服务器 $\rightarrow$ 代理受应答, 处理后回复

入侵检测系统: 执行入侵检测的硬/软件产品

发现入侵攻击, 用户滥用特权 前提: 入侵-合法可区分

问题 { 充分可靠提取描述行为特征的数据
依据数据高效判断

基本原理: 误用检测、异常检测 (看图说话)

- 基于主机: 监视、分析主机的审计记录 可疑 → 采取措施 对IDS分析很有用 详细取证
- 基于网络: 放在共享网段的重要位置 监听、采集可疑数据包
- 异常检测: 根据行为、资源使用的正常程度
- 误用检测: 根据已知、定义好的的模式判断是否出现

据图分析 Agent 的 IDS 主要工作机制:

基于代理的分层顺序控制和报告结构、收发器监控所有代理、数据精简, 向监视器报告

Snort 检测引擎: 找链表头, 找到则向下找选项, 匹配则判为攻击包 监控整个网络数据 高级聚合

访问控制: 通过某种途径显式地管理着对所有资源的访问请求 根据安全策略要求做出判断 (许可/限制访问) 实现数据保密性和完整性机制的主要手段

- 认证: 第一道防线, 确认身份
 - 访问控制: 控制对信息的访问
 - 审计: 监视、记录相关活动
- 共同建立保护系统安全的基础

自主访问控制 (DAC): 允许某主体显式指定其他主体对信息的访问权

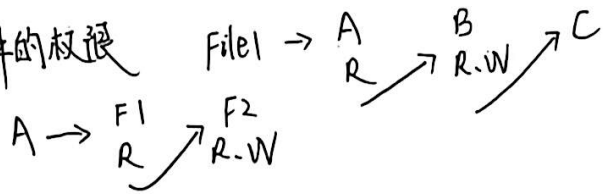
强制访问控制 (MAC): 每个个体有既定的安全属性, 能否操作取决于属性关系

RBAC: 用户与“角色”联系 “角色”为可执行操作的集合

① 访问控制表 以文件为主, 后连各用户对该文件的权限

② 能力关系表 以用户为主, 后连各文件

③ 权限关系表 将用户、文件、权限一一列出



可信计算机系统评价准则 A类最高

访问控制措施: 自主访问控制 强制访问控制 基于角色的访问控制 域和类型执行的访问控制

漏洞是在硬件、软件、协议的实现或系统安全策略上存在的缺陷, 可使攻击者在未授权情况下访问/破坏系统

产生必然性 检测只能证明错误存在, 而不能证明其不存在

信息型漏洞探测技术: 通过探测目标的型号、允许的操作系统版本、配置、补丁等情况确定其存在的漏洞

方便、不具破坏性 难下定论

攻击型漏洞检测: 模拟网络入侵, 进行无恶意攻击尝试 有局限性 有一定负面影响 专/通用语言 成熟工程

TCSEC: A, B, C1

ITSEC: E0, E1... E6

CC: EAL1 ~ EAL7

计算机病毒: 编制或在计算机程序中插入的破坏计算机功能/毁坏数据/影响

计算机使用的能自我复制的一组计算机指令或程序代码

主要特征: 是一个程序、具有传染性、传染方式是修改其他程序/自身拷贝

引导模块: 先成驻留内存、获取控制权

传染模块: 侵入系统

发作模块: 实施破坏

磁盘结构

文件系统 - 磁盘结构
一部分引导扇区、一部分其他扇区
文件型 感染并依附于可执行文件、外壳型

内存驻留

在系统启动时被装入内存高端
修改内存向量描述符
运行宿主程序时装入内存

窃取、修改中断的入口地址 插入病毒体 中断

Word 模式 -> 文件格式 资料 + 宏存于 .doc 宏感染 通过 .doc .dot 自我复制、传播

特征代码: 由已知代码 简单 慢

校验和: 将正常内容计算, 定期检查 易误报、不明确

行为检测: 利用特有行为特征 不能识别、难实现

磁盘备份 { 磁盘阵列 -> ① 磁盘延伸 ② 磁盘或数据镜像
磁盘镜像: 系统产生的各个 I/O 都在两个磁盘上进行

功能结构

主体 { 信息收集 扫描探测
攻击决策 自我推进
漏洞 { 实体隐藏 宿主破坏
信息通信 远程控制 自动升级

① 软件镜像 ② 外部磁盘子系统上的镜像 ③ 主机 I/O 控制器镜像

双机备份 { 纯软件: 公用网实时
灾难备份: 异步传 定时同步
共享磁盘阵列: 共享独立的存储子系统
双机单柜: 仅主机用阵列 实时
双机双柜: 都用阵列 实时

WLAN 安全标准 { WEP: 有线等价保密。保护机密性、完整性, 访问控制
不正确加密
WPA: 使用临时密钥完整性协议 { 802.1X 认证
预共享密钥
增强
WPA2: 802.11i 完整实现

访问控制技术: MAC 地址访问控制、服务区认证

数据加密技术: 对传输

端口访问技术: IEEE 802.1X 对设备安全认证、授权

数据校验技术: 确保传输数据完整性

云安全威胁 { 多租户高效、安全资源共享: 恶意租户 (抢占、侧信道方法)
租户角色信任关系保证: 防止提供商窃取
个性化、多层次的安全保障机制:

基于 TPM 的 TCCP 用户使用基于 TPM 的封闭虚拟环境 信息交由可信平台管理 管理者仅负责资源调度
可信虚拟机监控 TVM 可信网络 TC

云计算安全服务体系 { 云基础设施服务: 基石, 抵抗外部攻击, 证明自己无法破坏用户数据与应用
云基础服务: 为云应用提供共性信息安全服务
云应用服务: 与用户需求紧密结合

社会的法律政策、规章制度措施; 技术措施; 审计和管理措施

保密性 -> 完整性、可用性、可控性、不可否认性

保护: 传统安全
检测: 对信息、对攻击、对漏洞
响应: 保证高效运行
恢复: 灾难恢复
保护不行: 响应 + 检测
恢复: 最后的手段